



Data Security Governance Guideline

Version: 3.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	4
2. Functional Scope and Target Groups	5
2.1. Functional scope of applicability	5
2.2. Target groups	5
2.3. Transition period	6
3. Definitions	7
3.1. Requirements	7
3.2. Explanation of requirements and key definitions	8
4. Requirements	9
4.1. Requirement	9
5. Roles and Responsibilities	19
5.1. Creator	19
5.2. Guideline Owner	19
6. Appendix	20
6.1. Contact Information	20
6.2. Document History	20
6.3. Related Written Rules	20
6.4. Supporting Document	21
6.5. Abbreviations	21

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The **Data Security Governance Guideline** (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Identify	3. Develop and implement an appropriate set of procedures for information labelling in line with the classification scheme adopted from ICT risk-related guidelines.	4.2
Protect	3. Put in place information transfer rules, procedures, or agreements for all types of transfer facilities within the organization and between the organization and other parties.	4.3
Protect	6. Protect information stored on, processed by or accessible via user endpoint devices.	4.3
Protect	7. Restrict and manage the allocation and use of privileged access rights.	4.3
Detect	1. Define, implement, monitor, and regularly test detection processes and mechanisms to promptly detect anomalous activities including network performance issues and ICT-related incidents, and identify potential material single points of failure.	4.4

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy and [Data Leakage Prevention Strategy \(DLP Strategy\)](#).

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that manages, owns, or is related to applicable Data Security topic

Table 2: Scope

2.2. Target groups

Within the scope of the current Data Security Governance Guideline below is addressed the list of applicable target groups and operation areas¹:

Target group	Key message
ICT Risk Oversight	To oversee the development, implementation, and enforcement of Data Leakage Prevention policies and procedures and assess related risk.
ICT Operational Management	To implement and manage protection measures and procedures, and to support the integration of technologies with other IT infrastructure and systems.
Business Management	To implement, manage applicable security solutions, controls and monitor for potential risks ensuring the security and integrity of systems and data.

Table 3: Target groups

¹ For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Levels of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4. Requirements

4.1. Requirement

ID: 1 (version 3.0)	Labelling of information
1 DOR.ICT.DSG.LOI.001	Information must be labelled considering its confidentiality and business impact².
1.1 DOR.ICT.DSG.LOI.002	Information must be labelled, considering its confidentiality, business impact³ and in accordance with the below listed labels: - “Strictly Confidential” - information with a business impact classified as “Critical” and limited for the use within a very limited group of people, typically protected by regulation or law. - “Confidential” - information with a business impact classified as “Major” and limited for use only by a restricted group of people. - “Internal” - information with a business impact classified as “Minor” and limited for use only within the legal entities. Asset-Types: Information, Business Process, Desktop Application Key References: ISO 27001:2022 Cor 202203 A.5.13
1.2 DOR.ICT.DSG.LOI.003	Information classified as “Public” (information with a business impact⁹ classified as “Negligible” and limited to and authorized for general use inside and outside the legal entity) and “External” (Information with a business impact⁹ classified as “Minor” and authorized for the use inside and outside of DBG) should be labelled. Asset-Types: Information, Business Process, Desktop Application Key References: ISO 27001:2022 Cor 202203 A.5.13
1.3 DOR.ICT.DSG.LOI.004	All physical and printable electronic documents classified as “Internal” “Confidential”, “Strictly Confidential” should be labelled based on the confidentiality of included information at the time when they are created and before printing. Asset-Types: Information, Business Process, Desktop Application Key References: ISO 27001:2022 Cor 202203 A.5.13
1.4 DOR.ICT.DSG.LOI.006	Process(es), control(s) should be established to monitor, track and enforce applicable controls over the declassification of emails, documents ensuring proper labelling and protection. Measures must be implemented to prevent label circumvention when file formats are changed •. Asset-Types: Information, Business Process, Desktop Application Key References: ISO 27001:2022 Cor 202203 A.5.13

² This requirement applies only to information processed as part of manual data handling activities. However, all information must be protected appropriately as outlined in the other guidelines.

³ The impact classification can be found in ICT Risk Management guideline (requirement ID 4.2) or Information Risk Management Procedure (chapter 4.3)

ID: 2 (version 3.0)	Data Crown Jewel Inventory & Data Flow Management
2 DOR.ICT.DSG.DCJ.001	Data flows for all Data Crown Jewels must be documented, and the Data Crown Jewel inventory as well as the associated Data Flow Registry must be maintained and regularly updated.
2.1 DOR.ICT.DSG.DCJ.002	Data flows for each Data Crown Jewel must be documented, maintained in centralized Data Flow Registry●. Data Crown Jewels⁴ are mission-critical data whose unauthorized disclosure would cause intolerable and existential business impact. This includes but is not limited to: - Regulatory Impact: Severe regulatory consequences such as the revocation of essential licenses or authorizations, making continued business operations impossible. - Financial Impact: Severe financial losses that threaten the organization's solvency or ability to continue operations. - Customer and Market Trust Impact: Severe and sustained harmful customer or market reaction, e.g. significant market movements that threaten business viability. - Operational Impact: Permanent or sustained disruption of critical core services and operations that prevents the organization from functioning Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.9, A.5.13, A.5.14, A.5.33, A.8.12
2.2 DOR.ICT.DSG.DCJ.003	The inventory of Data Crown Jewels and associated Data Flow Registry must be reviewed at least annually to ensure completeness and ongoing relevance●. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.9, A.5.13, A.5.14, A.5.33, A.8.12

ID: 3 (version 3.0)	DLP tool and measure implementation
3 DOR.ICT.DSG.MON.001	It must be ensured that unauthorized data disclosure is mitigated and transferred data is protected.
3.1 DOR.ICT.DSG.MON.002	Data Leakage Prevention tool and measures must be implemented to identify, monitor, and detect data leakage and protect data in transit. This must protect data against unauthorized disclosure, copying, or transmission, through risk-based approach. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, End User Device, Mobile Device, Processing Peripheral, Other Device, Network Connection Key References: DORA RTS RMF A.14.1b), ISO/IEC 27001: 2022 A.5.10, A.5.14, A.5.33, A.8.12

⁴ Unlike sensitivity labels that are applied by end users (e.g., Public, External, Internal, Confidential, Strictly confidential), the identification of Data Crown Jewels follows a top-down approach driven by senior management.

ID: 4 (version 3.0)	Email monitoring and protection						
4 DOR.ICT.DSG.E MA.001	Data Leakage Prevention measures for communications over email ⁵ must be implemented.						
4.1 DOR.ICT.DSG.E MA.002	Monitoring of emails must be enabled, at least based on the classification labels. Emails – especially non-labelled outbound ones – and attachments must be subject to appropriate technical controls.						
		Public	External	Internal	Confidential	Strictly Confidential	Data Crown Jewels
	Labelling Validation with Content Monitoring ⁶	– Organizational control mandatory for emails to external recipient • – Technical control mandatory for emails to external recipient, following a risk-based approach and wherever reasonable implementable ⁷ •					– Organizational control mandatory for emails to external recipients• – Technical control mandatory for emails to external recipients•
	Recipient validation ⁸	Not required	Organizational control mandatory for emails to external recipients•	– Organizational control mandatory for emails to external recipients• – Technical control mandatory for emails to external recipient, following a risk-based approach and wherever reasonable implementable ¹³ •		– Organizational control mandatory for emails to external recipients• – Technical control mandatory for emails to external recipients•	
	Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10						
4.2 DOR.ICT.DSG.E MA.003	DBAG and/or adopting legal entity email addresses created for externals sending strictly confidential messages must be secured by specific DLP measures mentioned above. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10						
4.3	The maximum principle must be applied, ensuring that the overall classification for email reflects the highest sensitivity of any contained component wherever possible•. Asset-Types: Information, Business Process, Desktop Application Key References: ISO 27001:2022 Cor 202203 A.5.13						

⁵ This control requirement applies to Microsoft 365 email only

⁶ Refers to organizational and technical controls that support proper validation of sensitivity labels on emails sent to external recipients by checking if the assigned label correctly reflects the actual content.

⁷ Provided that such implementation does not introduce material latency or otherwise impair business operations.

⁸ Refers to organizational and technical controls, e.g. with confirmations by the users, ensuring that external email recipients are authorized before sending the information outside the organization to mitigate data leakage risk.

ID: 5 (version 3.0)	DLP Endpoint protection
5 DOR.ICT.DSG.EPP.001	DLP Endpoint protection must be implemented to protect workstation devices and user equipment from data leakage, restricting the use of removable storage media by default, subject only to temporary, monitored exceptions based on legitimate need.
5.1 DOR.ICT.DSG.EPP.002	All hardware and activation of ports that can be used for connection of storage media must be blocked. The necessary ports to use storage media must be enabled temporarily only if there is a business, technical or operational need, unless there is no other data access solution and exception process must be established, implemented●. Asset-Types: Information, Business Process, Hardware Appliance, End User Device, Mobile Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.10
5.2 DOR.ICT.DSG.EPP.003	Standard software images must be designed and implemented for all workstation devices of legal entities, ensuring that ports for storage media connections are deactivated, anti-malware protection is in place, and administrator rights for users are disabled. Asset-Types: Information, Business Process, End User Device, Mobile Device Key References: ISO 27001:2022 Cor 202203 A.5.10
5.3 DOR.ICT.DSG.EPP.004	If there is a need to use removable storage media, transfer of information to such storage media must be monitored. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.10

ID: 6 (version 3.0)	Data Leakage Prevention for online and instant messaging services							
6 DOR.ICT.DSG.I MS.001	Use of Online and Instant messaging services must be restricted to authorized services, with appropriate measures applied when processing information based on its classification							
6.1 DOR.ICT.DSG.I MS.002	Use of online services must be limited as below:							
			Public	External	Internal	Confidential	Strictly Confidential	Data Crown Jewels
	Online file sharing	Secure File Transfer (e.g. Data room)	Not required	Not required	Not required	Should	Mandatory	Mandatory●

		Confirmat ion Request	Not required	Not required	Not required	Not required	Should●	Mandatory●
	File upload to blacklisted/ isolated WebProxy Internet URL	Block	Should	Should	Should	Should	Mandatory	Mandatory
	File upload to non- blacklisted/ non- isolated WebProxy Internet ⁹ URL	Confirmat ion Request	Not required	Not required	Mandatory	Mandatory	Mandatory	Not required
		Block ¹⁰	Not required	Not required	Not required	Not required	Not required	Mandatory
	Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10, A.5.33, A.8.12							
6.2 DOR.ICT.DSG.I MS.003	Electronic communication must be limited by using legal entity's authorized instant messaging services and by using legal entity's email accounts. Listings of authorized instant messaging services must be defined by legal entity. Asset-Types: Information, Business Process, Desktop Application Key References: ISO 27001:2022 Cor 202203 A.5.10, A.5.33, A.8.12							

ID: 7 (version 3.0)	Secure Printing of Sensitive Information						
7 DOR.ICT.DSG.SP R.001	It must be ensured that printing activities ¹¹ are controlled in accordance with the classification of information to prevent data leakage.						
7.1 DOR.ICT.DSG.SP R.002	For “Strictly Confidential” information or Data Crown Jewels, appropriate confirmation mechanisms must be implemented prior to printing:						
		Public	External	Internal	Confidential	Strictly Confidential	Data Crown Jewels
Confirmation Request	Not required	Not required	Not required	Not required	Should●	Mandatory●	
Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10, A.5.33, A.8.12							

⁹ URL Black & Whitelist categories can be found in Procedure for WebProxy Internet URL Access Black & Whitelist Management

¹⁰ Unless an exception has been requested by respective Information Owner

¹¹ Refers to both physical and virtual printing (e.g., hard-copy printing, Print to PDF).

ID: 8 (version 3.0)	Storage media management
8 DOR.ICT.DSG.SMM.001	Management procedures and measures must be in place to securely manage storage media and the data it contains throughout its lifecycle.
8.1 DOR.ICT.DSG.SMM.002	All copies of storage media should be clearly marked as such. Multiple copies of sensitive data should be stored on separate media in separate locations. Asset-Types: Information, Business Process, Storage Media, Storage Key References: ISO 27001:2022 Cor 202203 A.5.33
8.2 DOR.ICT.DSG.SMM.003	All types of storage media should have its lifetime defined, type and frequency of tests for guaranteeing the availability of stored data without degradation. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.33
8.3 DOR.ICT.DSG.SMM.004	Legal entity data which needs to be retained longer than the life of the storage media must be stored on new media before the end of its lifetime. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.33
8.4 DOR.ICT.DSG.SMM.005	To mitigate the risk of media degrading while stored data is still needed, the data should be transferred to fresh storage media before becoming unreadable. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.33
8.5 DOR.ICT.DSG.SMM.006	Where electronic storage media are chosen, procedures to ensure the ability to access records throughout the retention period should be established. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.33
8.6 DOR.ICT.DSG.SMM.007	Storage should be chosen such that required records can be retrieved in an acceptable time frame and format. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.33
8.7 DOR.ICT.DSG.SMM.008	For all storage media it must be defined if it is authorized to be taken off-premises. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.33

ID: 9 (version 3.0)	Protection of media
9 DOR.ICT.DSG.PMD.001	It must be ensured that all media is securely handled, stored, and transported to prevent unauthorized access or data leakage considering the classification.

9.1 DOR.ICT.DSG.PMD.002	All media containing information categorized as “External”, “Internal”, “Confidential”, “Strictly Confidential” or “Data Crown Jewel” must be protected against unauthorized access, misuse, or corruption during transportation. Asset-Types: Information, Business Process, Storage Media, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.7.10
9.2 DOR.ICT.DSG.PMD.003	Media packaging must ensure that the content is protected from any physical damage and loss. Asset-Types: Information, Business Process, Storage Media, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.7.10
9.3 DOR.ICT.DSG.PMD.004	Depending on the classification label (described in requirement ID 1) of the information in the storage media to be transported, tamper evident or tamper-resistant controls should be used. Asset-Types: Information, Business Process, Storage Media, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.7.10
9.4 DOR.ICT.DSG.PMD.005	Logical and physical access restrictions to storage media must be applied to prevent access of unauthorized personnel, exceptions may be provided on a temporary basis. This includes at least the following actions: Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.10
9.4.1 DOR.ICT.DSG.PMD.006	Storage media must be kept only in locked or secure places if it is not currently used. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.10
9.4.2 DOR.ICT.DSG.PMD.007	All storage media should be securely stored in both logical and physical manner and in accordance with the manufacturer’s recommendation. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.5.10

ID: 10 (version 3.0)	Transfer of media
10 DOR.ICT.DSG.TMD.001	The transfer of media must be securely managed to ensure the protection and integrity of the information throughout the entire transfer process.
10.1 DOR.ICT.DSG.TMD.002	Courier identification standards and procedures to verify the identification of couriers should be defined to ensure that only authorized, reliable transport or couriers are used for the transfer of media. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.7.10

10.2 DOR.ICT.DSG.TMD.003	Media transport logs should be kept over the whole lifecycle if this is possible. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.7.10
-----------------------------	---

ID: 11 (version 3.0)	Secure data and media disposal
11 DOR.ICT.DSG.SMD.001	Procedures and measures for secure disposal of data and media containing information must be defined and implemented.
11.1 DOR.ICT.DSG.SMD.002	The procedures and measures for secure disposal of data, present on premises or stored externally, must be implemented proportionally to the classification label of information and make sure that the data is deleted securely and completely. Asset-Types: Business Process, Storage Media, Storage Key References: DORA RTS RMF A.11. 2h), 2i)
11.2 DOR.ICT.DSG.SMD.003	The procedures and measures for secure disposal of media containing information must be implemented proportionally to the classification label of information, ensuring data is irrevocably deleted from storage media, storages, databases, and endpoint devices. Asset-Types: Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Storage, Room, Datacenter Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.1 DOR.ICT.DSG.SMD.004	Media must be securely disposed by using disposal mechanism approved by the legal entity. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media, Storage Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.2 DOR.ICT.DSG.SMD.005	Media must be disposed of in a way that renders the stored data unrecoverable by any forensic means. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media, Storage Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.3 DOR.ICT.DSG.SMD.006	Media must be securely and safely stored before disposal, by storing in locked storage rooms or containers. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media, Storage, Room Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.4 DOR.ICT.DSG.SMD.007	Disposal of media must only be performed in areas intended for this purpose. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media, Storage Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.5 DOR.ICT.DSG.SMD.008	All steps of the media disposal process must be suitably documented. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media, Storage, Room Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.6 DOR.ICT.DSG.SMD.009	All media items should be collected and disposed of securely, rather than attempting to separate out the sensitive items.

	Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media, Storage, Room Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.7 DOR.ICT.DSG.SMD.010	Media containing information should be stored and disposed of securely by incineration or shredding, or secure erasure of data for use by another application within the organization. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media, Storage Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.8 DOR.ICT.DSG.SMD.011	When accumulating media for disposal, consideration should be given to the aggregation effect, which can cause a large quantity of non-confidential information to become confidential. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media, Storage Key References: DORA RTS RMF A.11. 2h), 2i)
11.2.9 DOR.ICT.DSG.SMD.012	Equipment containing internal, confidential, or strictly confidential information must be rendered unrecoverable via a secure wipe program prior to equipment disposal. Asset-Types: Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Storage Key References: ISO 27001:2022 Cor 202203 A.7.14
11.3 DOR.ICT.DSG.SMD.013	Only suppliers in accordance with Third-Party ICT Risk Management Guideline must be used for secure collection and disposal of media. Asset-Types: Information, Business Process, Storage Media Key References: ISO 27001:2022 Cor 202203 A.7.10

5. Roles and Responsibilities

5.1. Creator

The creator of the Data Security Governance Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of the Data Security Governance Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the Data Security Governance Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the Data Security Governance Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact ICT Risk Governance & Advisory in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	28.01.2026	Material Update
2.1	20.05.2026	Minor Update
3.0	19.08.2026	Annual review with material changes

Coordination before publication

Version	Date	Task	Name
3.0	25.05.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	22.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	22.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
3.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	Data Leakage Prevention Procedure

6.4. Supporting Document

The following supporting document is applicable to this Guideline:

- Side Letter to the DSG Guideline v3.0

6.5. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
